

SNEVAM – Security & Access Control Document (SACD)

Version

1.0

Product

SNEVAM – 3D Luxury Accessories Platform

Purpose

This document defines the security architecture, access management policies, authentication mechanisms, authorization controls, data protection standards, and operational security requirements for the Snevam platform.

Security Objectives

Primary Goals

- Protect customer data
 - Protect payment transactions
 - Prevent unauthorized access
 - Secure administrative functions
 - Ensure platform availability
 - Maintain customer trust
-

Security Principles

Core Principles

Least Privilege

Users only receive permissions required for their role.

Zero Trust

All requests must be authenticated and authorized.

Defense in Depth

Multiple layers of security across frontend, backend, infrastructure, and database.

Secure by Default

All services start with the most restrictive security settings.

User Roles

Customer

Permissions

- Register account
- Login
- Browse products
- Add to wishlist
- Place orders
- Manage profile

Restrictions

- Cannot access admin APIs
 - Cannot access internal analytics
 - Cannot modify products
-

Customer Support

Permissions

- View customer profiles
- View orders
- Update support tickets

Restrictions

- Cannot modify payments
 - Cannot access system settings
-

Inventory Manager

Permissions

- Manage stock
- Update inventory
- View products

Restrictions

- Cannot access financial reports
 - Cannot manage users
-

Store Manager

Permissions

- Manage products
- Manage inventory
- View orders
- Manage promotions

Restrictions

- Cannot change security settings
-

Administrator

Permissions

- Full platform management
- User management
- Product management
- Analytics access

Restrictions

- Cannot access encrypted secrets directly
-

Super Admin

Permissions

- Complete system control
- Infrastructure management
- Security policy management

Restrictions

- Logged and audited continuously
-

Authentication

Supported Methods

Email + Password

Requirements:

- Minimum 12 characters
 - Uppercase required
 - Lowercase required
 - Number required
 - Special character required
-

Google OAuth

Supported Provider:

- Google

Benefits:

- Reduced password risk
 - Simplified onboarding
-

OTP Authentication

Channels:

- SMS OTP
- Email OTP

OTP Expiration:

5 minutes

Maximum Attempts:

5

Password Security

Hashing

Algorithm:

bcrypt

Rounds:

12+

Password Policy

Minimum Length:

12

Password History:

Last 5 passwords blocked

Password Expiration:

Optional for admin users

Multi-Factor Authentication

Required For

- Administrators
- Store Managers

- Super Admins
-

Methods

- Authenticator App
 - Email OTP
 - Backup Recovery Codes
-

Session Security

Session Duration

Customer

30 Days

Admin

8 Hours

Super Admin

4 Hours

Session Controls

- Device tracking
 - Forced logout
 - Refresh token rotation
 - Suspicious activity detection
-

Authorization

Model

Role-Based Access Control (RBAC)

API Authorization

Every API request must verify:

- User Identity
 - User Role
 - Resource Access
 - Permission Scope
-

JWT Security

Access Token

Expiration:

15 Minutes

Refresh Token

Expiration:

30 Days

Stored:

HTTP-only secure cookies

Data Encryption

In Transit

TLS 1.3

HTTPS mandatory

At Rest

AES-256 Encryption

Applies To:

- Customer Data
 - Orders
 - Addresses
 - Payment Metadata
-

Payment Security

Payment Providers

- Razorpay
 - Stripe
-

Rules

- No card storage
 - PCI-DSS compliance
 - Tokenized payments only
-

Customer Data Protection

Protected Information

- Name
 - Email
 - Phone
 - Address
 - Order History
-

Sensitive Data Handling

Never expose:

- Passwords
- Tokens

- Internal IDs
 - Payment Credentials
-

API Security

Protections

Rate Limiting

Customer APIs:

100 requests/minute

Admin APIs:

50 requests/minute

Input Validation

Validation Library:

Zod

All requests validated server-side.

SQL Injection Protection

- Parameterized Queries
 - ORM Validation
-

XSS Protection

- Output Encoding
 - Content Security Policy
-

CSRF Protection

Enabled for authenticated requests.

Frontend Security

Security Headers

Content-Security-Policy

Strict-Transport-Security

X-Frame-Options

Referrer-Policy

Permissions-Policy

Browser Protections

- Secure Cookies
 - SameSite Cookies
 - No localStorage for tokens
-

File Upload Security

Allowed Types

Images:

- JPG
- PNG
- WEBP

3D Models:

- GLB
 - GLTF
-

Restrictions

Maximum Size:

25 MB

Virus Scan Required

Malware Detection Required

Admin Panel Security

Access Requirements

- MFA Mandatory
 - IP Monitoring
 - Audit Logging
-

Monitoring

Track:

- Login Attempts
 - Product Changes
 - Permission Changes
 - Refund Actions
-

Audit Logging

Events Logged

Authentication

Authorization Failures

Product Updates

Order Changes

Admin Actions

Security Events

Retention

365 Days

Infrastructure Security

Cloud Security

AWS Best Practices

Private Subnets

Security Groups

Network Isolation

Secrets Management

Store In:

AWS Secrets Manager

Never Store In:

- Source Code
 - Git Repositories
 - Frontend Variables
-

Monitoring & Detection

Tools

Sentry

CloudWatch

Vercel Analytics

Alerts

Failed Login Spikes

Suspicious API Activity

Payment Failures

Privilege Escalation Attempts

Backup Policy

Database

Daily Backup

Media Assets

Daily Backup

Retention

90 Days

Disaster Recovery

Recovery Time Objective (RTO)

4 Hours

Recovery Point Objective (RPO)

1 Hour

Compliance

Standards

PCI-DSS

GDPR Principles

Data Protection Best Practices

Incident Response

Severity Levels

Critical

High

Medium

Low

Critical Incidents

Examples:

- Data Breach
- Payment Compromise
- Infrastructure Breach

Response Time:

15 Minutes

Security Testing

Required Tests

Static Analysis

Dependency Scanning

Penetration Testing

Vulnerability Assessment

Authentication Testing

Authorization Testing

Release Security Checklist

Before Production Release:

- Security Scan Passed
- MFA Enabled
- Secrets Rotated
- Dependency Audit Passed
- Penetration Test Completed
- Backup Verified
- Monitoring Enabled

Success Metrics

Security Incidents: 0 Critical

Data Breaches: 0

Account Takeovers: < 0.01%

Uptime: 99.9%

Mean Time To Detect: < 15 Minutes

Mean Time To Resolve: < 2 Hours